

THREAT ASSESSMENT WORKBOOK

Digital Content #8 — Ransomware + AI: You Can Restore the Files. You Can't Restore the Trust.

Purpose: Assess your organization's exposure to ransomware in multi-agent systems — where the payload is not a malicious binary but a poisoned instruction that propagates through agent-to-agent trust and inherited non-human identities, corrupting decision integrity so that even a fully restored system carries decisions you can no longer verify. Map your agent trust edges and decision-lineage coverage, assign ownership, and build a prioritized response plan.

01 Exposure Check

Answer Yes / No / Unknown for your environment. Every Unknown is a gap. Three or more Unknowns = this is your next tabletop agenda.

Question	Yes	No	Unknown / Gap	Notes
Do we maintain an inventory of the autonomous agents in our environment and the systems each can act on?				
Do we know which agents trust and act on other agents' outputs without independent verification?				
Do we capture agent decision lineage — what each agent was instructed to do and which upstream decision it trusted — not just what it executed?				
Could we distinguish, after an incident, a decision the fabric made correctly from one an attacker steered?				
Do our agents share or inherit non-human identities / tokens that would let a compromise propagate as authorized activity?				
Is there a defined "recovered" state for the fabric that means re-attested decisions, not just restored systems?				
Have we tested recovery from an integrity compromise (poisoned decisions), not only an availability compromise (encryption)?				
Could we prove to the board which agent decisions in the last 30 days are clean?				

AGENT FABRIC INVENTORY (list known autonomous agents, what each can act on, whose output it trusts, and whether it shares a non-human identity)

Agent / Name	Systems It Can Act On	Trusts Output Of	Shared NHI?

02 Propagation & Trust-Edge Audit

A poisoned instruction becomes an incident when it can propagate through agent trust and inherited identity. Audit the trust graph and the propagation controls.

Question	Yes	No	Unknown / Gap	Notes
Have we mapped agent-to-agent trust relationships — which agent consumes and acts on which agent's output?				
Are cross-agent instructions that trigger consequential action (payments, provisioning, record changes) subject to attestation or a human checkpoint?				
Is each agent's authority to instruct other agents explicitly bounded and revocable, rather than implicit?				
Have we eliminated long-lived or shared tokens that would let a compromise move between agents as sanctioned automation?				
Is there alerting when an agent begins issuing instructions or taking actions outside its historical pattern?				
Could a single poisoned instruction reach a consequential system without crossing a human or attestation boundary?				

TRUST-EDGE REVIEW (for each consequential trust edge, record whether it is attested, bounded, and the gap to close)

Trust Edge (Agent → Agent)	Consequential?	Attested / Bounded?	Gap / Action

03 Detection & Recovery Baseline

Encryption trips alerts. A poisoned instruction riding authorized trust does not. Detection and recovery must be integrity-aware, not just availability-aware.

Question	Yes	No	Unknown / Gap	Notes
Does monitoring baseline normal agent decision behavior and flag deviations in intent, not just volume?				
Is agent decision lineage captured immutably, so it survives the incident it is needed to investigate?				
Do backups and snapshots cover decision provenance, or only data and system state?				
Do we have a per-agent re-attestation procedure to re-establish a trusted baseline after compromise?				
Can we quarantine an agent's outputs and every downstream consumer of them, not just its host?				
Have we tested recovery against a simulated poisoned-instruction scenario, not only file encryption?				
Is inhibited recovery (backup tampering, snapshot deletion) monitored on the fabric's own state stores?				

04 Governance Gap — Who Owns What

A poisoned decision is real whether or not anyone owns the control that would have caught it. Map ownership across inventory, propagation, detection, and recovery before an incident surfaces the gap.

Function	Owner (Name / Role)	Last Reviewed	Gap
Agent fabric inventory & trust-edge discovery			
Agent decision lineage / intent provenance capture			
Cross-agent instruction attestation & authority bounding			
Non-human identity / token isolation across agents			
Integrity-aware detection & agent-behavior monitoring			
Recovery architecture & per-agent re-attestation			
Ransomware tabletop covering integrity, not just encryption			

05 Five Questions for Your Next Executive Meeting

Bring these to the board. If the honest answer to the first is “we don’t know,” that is the finding.

#	Question	Your Answer / Status
01	If one agent were compromised today, could we list every downstream agent and decision that trusted its output?	
02	What is our definition of “recovered” — restored systems, or re-attested decisions — and do we have a procedure for the second?	
03	How many agent-to-agent trust relationships exist in our fabric, and which of them are revocable?	
04	Could we prove to a regulator or the board which agent decisions in the last 30 days are clean?	
05	Does our ransomware tabletop assume file encryption — or a poisoned instruction we cannot cleanly roll back?	

06 Directives — Assign an Owner and a Date

Five moves, in order — inventory, constrain, detect, re-attest, rehearse. Assign each directive an owner and a target date.

#	Audience	Directive	Owner	Done By
01	CISO	Inventory the agent fabric. Every autonomous agent, the systems it can act on, and the agents whose output it trusts. If it acts and isn't a person, it's on the list.		
02	CISO	Map agent-to-agent trust edges. Treat the collaboration graph as your lateral-movement map. Implicit trust between agents is the propagation vector.		
03	CISO	Bound and make revocable each agent's authority to instruct others. Authority without a boundary propagates without a limit.		
04	CISO	Require attestation on consequential cross-agent instructions. A human checkpoint or attestation on instructions that move money, provision access, or change records.		
05	CISO	Isolate non-human identities across agents. Eliminate shared and long-lived tokens that let a compromise travel between agents as authorized activity.		
06	IR	Capture agent decision lineage immutably. Log what each agent was instructed to do, which upstream decision it trusted, and on whose authority — intent, not just activity.		
07	IR	Baseline agent decision behavior and alert on deviation. Flag anomalies in intent and cross-agent instruction, not just in request volume.		
08	IR	Build and test per-agent re-attestation. Define "recovered" as re-attested decisions, not restored servers. Rehearse how you re-establish a trusted baseline.		
09	IR	Contain at the trust layer. Quarantine a compromised agent's outputs and every downstream consumer — not just its host.		
10	IR	Run an integrity-aware ransomware tabletop. Assume a poisoned instruction and decision-integrity loss, not only encryption. Monitor for inhibited recovery on fabric state stores.		

Assessment prepared by Matsui LLC · matsuihq.ai